Министерство науки и высшего образования Российской Федерации
Федеральное государственное автономное образовательное учреждение
высшего образования
«Национальный исследовательский университет ИТМО»

Факультет Программной инженерии и компьютерной техники

Лабораторная работа №1
Разработка защищенного REST API с интеграцией в CI/CD
Информационная безопасность

Работу выполнили:
группа P3414
Белик Тимур Алексеевич

Преподаватель:

Санкт-Петербург,
2026

Github
https://github.com/krokodelopuma/ib_lab1
Текст файла README.md

Информационная безопасность
Лабораторная работа №1
Стек
Python 3.10
Flask 3.1.3
Flask-SQLAlchemy (ORM)
Flask-Bcrypt (хэширование паролей)
PyJWT (JWT-токены)
SQLite

Описание API

POST /api/register: метод для регистрации пользователя (принимает логин и пароль).
{
"username": "student",
"password": "StrongPass123"
}

POST /auth/login: метод для аутентификации пользователя (принимает логин и пароль, возвращает JWT).
{
"username": "student",
"password": "StrongPass123"
}

GET /api/data: метод для получения данных (список пользователей). Доступ только у аутентифицированных пользователей.
Описание реализованных мер защиты
От SQLi код защищен с помощью ORM SQLAlchemy. Все запросы к БД выполняются через параметризованные вызовы, конкатенация строк в SQL не используется:
user = User.query.filter_by(username=data['username']).first()

От XSS защищен с помощью экранирования пользовательских данных перед возвратом в ответе API:
from markupsafe import escape
output = [{'id': u.id, 'username': escape(u.username)} for u in users]
От Broken Authentication:
пароли хэшируются через bcrypt (автоматическая соль, адаптивная сложность)
при успешном логине выдается JWT-токен (HS256, срок жизни 30 минут)
на защищенных эндпоинтах работает middleware @token_required, которое проверяет подпись и срок действия токена:
hashed = bcrypt.generate_password_hash(data['password']).decode('utf-8')
и
token = jwt.encode({
'user_id': user.id,
'exp': datetime.datetime.now(datetime.UTC) + datetime.timedelta(minutes=30)
}, app.config['SECRET_KEY'], algorithm="HS256")

Отчеты из pipeline
В CI/CD настроены два security-сканера:
SAST - Bandit (статический анализ Python-кода).
SCA - pip-audit (проверка зависимостей на известные CVE).

Последний запуск пайплайна:
https://github.com/krokodelopuma/ib_lab1/actions/runs/42473011830

терминал 1(сервер)

```
(.venv) PS D:\IB> python app.py
 * Serving Flask app 'app'
 * Debug mode: on
WARNING: This is a development server. Do not use it in a production deployment. Use a production WSGI server instead.
 * Running on http://127.0.0.1:5000
Press CTRL+C to quit
 * Restarting with stat
 * Debugger is active!
 * Debugger PIN: 236-864-076
127.0.0.1 - - [08/Nov/2026 13:06:41] "POST /api/register HTTP/1.1" 201 -
127.0.0.1 - - [08/Nov/2026 13:06:41] "POST /auth/login HTTP/1.1" 200 -
127.0.0.1 - - [08/Nov/2026 13:06:41] "GET /api/data HTTP/1.1" 401 -
127.0.0.1 - - [08/Nov/2026 13:06:43] "GET /api/data HTTP/1.1" 200 -
```

терминал 2

```
Терминал  C:\Windows\Sys...\powershell.exe  C:\Windows\Sys...\powershell.exe  AI Agents

(.venv) PS D:\IB> curl.exe -X POST http://127.0.0.1:5000/api/register -H "Content-Type: application/json" -d '{\"username\":\"student4\",\"password\":\"StrongPass123\"}'
{
  "message": "Created"
}
(.venv) PS D:\IB> $r = curl.exe -s -X POST http://127.0.0.1:5000/auth/login -H "Content-Type: application/json" -d '{\"username\":\"student4\",\"password\":\"StrongPass12
3\"}'
(.venv) PS D:\IB> $r
{
  "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoxLCJleHAiOjE3OTQxMzQyMDF9.ACiiBhjqYYBrJt_s3qZDSn1q1_fB9VtpZgX9w5HvS2U"
}
(.venv) PS D:\IB> $tok = ($r | ConvertFrom-Json).token
(.venv) PS D:\IB> curl.exe -i http://127.0.0.1:5000/api/data
HTTP/1.1 401 UNAUTHORIZED
Server: Werkzeug/3.1.9 Python/3.14.10
Date: Sun, 08 Nov 2026 10:06:41 GMT
Content-Type: application/json
Content-Length: 33
Connection: close

{
  "message": "Token missing"
}
(.venv) PS D:\IB> curl.exe -i http://127.0.0.1:5000/api/data -H "Authorization: Bearer $tok"
HTTP/1.1 200 OK
Server: Werkzeug/3.1.9 Python/3.14.10
Date: Sun, 08 Nov 2026 10:06:43 GMT
Content-Type: application/json
Content-Length: 106
Connection: close

{
  "data": [
    {
      "id": 1,
      "username": "student4"
    }
  ],
  "requested_by": "student4"
}
(.venv) PS D:\IB>
```

Actions

